

AUTOPARTS PRO

รายงานการทดสอบ API ด้วย Postman

ระบบบริหารจัดการร้านค้าอะไหล่รถยนต์ออนไลน์ (AutoParts Pro)

วิชา	CSI204 ดิจิทัลแพลตฟอร์มสำหรับพัฒนาซอฟต์แวร์
อาจารย์ผู้สอน	อาจารย์ทินภัทร โบริรักษ์
ผู้จัดทำ	นายกฤษฎา ต่องไกรเลิศ
รหัสนักศึกษา	67115444
สาขา	นวัตกรรมการพัฒนาซอฟต์แวร์ (SIT)
มหาวิทยาลัย	มหาวิทยาลัยศรีปทุม (SPU)

ภาคการศึกษาที่ 3 ปีการศึกษา 2568 | มหาวิทยาลัยศรีปทุม

1. สมัครสมาชิกใหม่ (Register - Customer)

POST http://localhost:5000/api/auth/register **Status: 201 Created**

REQUEST BODY (JSON)

```
{
  "name": "กฤษฎา ต่องไกรเลิศ",
  "email": "postman@autopartspro.com",
  "password": "password1234",
  "phone": "0812345678",
  "address": "มหาวิทยาลัยกรุงเทพ"
}
```

RESPONSE BODY

```
{
  "success": true,
  "data": {
    "_id": "11",
    "name": "กฤษฎา ต่องไกรเลิศ",
    "email": "postman@autopartspro.com",
    "role": "user",
    "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6MTESIm1hdCI..."
  }
}
```

คำอธิบายการทดสอบ

เป็นการส่งข้อมูล JSON เพื่อลงทะเบียนผู้ใช้งานคนใหม่เข้าสู่ระบบในบทบาทของลูกค้าทั่วไป (Customer/User) ผ่าน API Endpoint โดยระบุข้อมูลที่จำเป็น เช่น ชื่อ-นามสกุล, อีเมล, รหัสผ่าน, เบอร์โทรศัพท์ และข้อมูลที่อยู่ส่งสินค้า เพื่อบันทึกลงสู่ฐานข้อมูล PostgreSQL

วิเคราะห์ผลลัพธ์

ระบบหลังบ้านประมวลผลสำเร็จและตอบกลับมามีสถานะ 201 Created พร้อมข้อมูลของผู้ใช้ที่ลงทะเบียนเสร็จสิ้นและ JWT Token บ่งชี้ว่าระบบฐานข้อมูลทำงานได้อย่างถูกต้อง ปลอดภัย และสามารถจัดเก็บข้อมูลสมาชิกใหม่เรียบร้อยแล้ว

นายกฤษฎา ต้องไกรเลิศ (รหัส 67115444)

หน้า 1

2. ล็อกอินลูกค้า (Login - Customer)

POST `{{baseUrl}}/auth/login` Status: **200 OK**

REQUEST BODY (JSON)

```
{
  "email": "postman@autopartspro.com",
  "password": "password1234"
}
```

RESPONSE BODY

```
{
  "success": true,
  "data": {
    "_id": "11",
    "name": "กฤษฎา ดั่งไกรเลิศ",
    "email": "postman@autopartspro.com",
    "role": "user",
    "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6Im1hdCI..."
  }
}
```

คำอธิบายการทดสอบ

ทดสอบส่งคำขอยืนยันตัวตน (Authentication) เพื่อเข้าใช้งานระบบของลูกค้า โดยส่งอีเมลและรหัสผ่านที่สมัครไว้ก่อนหน้านี้ไปยัง Endpoint ล็อกอินหลัก เพื่อรับสิทธิ์การเข้าใช้งานระบบในรูปแบบของสิทธิ์ผู้ใช้งานทั่วไป (role: "user")

วิเคราะห์ผลลัพธ์

เซิร์ฟเวอร์ตรวจสอบความถูกต้องและรหัสผ่านที่ถูกเข้ารหัสไว้สำเร็จ จึงส่งสถานะตอบกลับ 200 OK พร้อมข้อมูลโปรไฟล์เบื้องต้นและโทเคนสิทธิ์การใช้งาน (JWT Token) เพื่อบันทึกไว้ฝั่งไคลเอนต์สำหรับเรียกใช้งาน API ส่วนจำกัดสิทธิ์ในขั้นตอนต่อไป

นายกฤษฎา ต้องไกรเลิศ (รหัส 67115444)

หน้า 2

3. ล็อกอินผู้จัดการ (Login - Manager)

POST	{{baseUrl}}/auth/login	Status:	200 OK
REQUEST BODY (JSON)			
{ "email": "manager@autopartspro.com", "password": "manager123" }			
RESPONSE BODY			
{ "success": true, "data": { "_id": "3", "name": "Manager Staff", "email": "manager@autopartspro.com", "role": "manager", "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6ImYwIiwiaWF0IjE5OTkxMjQyNjA0fQ==" } }			

คำอธิบายการทดสอบ

เป็นการส่งข้อมูลยืนยันตัวตนของเจ้าหน้าที่ระบบที่มีบทบาทเป็นผู้จัดการ (role: "manager") เพื่อเข้าถึงแดชบอร์ดหลังบ้านและการควบคุมสต็อกสินค้า รวมถึงการคัดกรองหลักฐานการชำระเงินตามสิทธิ์การใช้งานที่ระบบกำหนด

วิเคราะห์ผลลัพธ์

ระบบยืนยันตัวตนสำเร็จ ตอบกลับมาด้วยรหัสสถานะ 200 OK และส่งโทเคนที่มีข้อมูลสิทธิ์ระบบบทบาทอย่างชัดเจนเป็น "manager" ทำให้ฝั่งหน้าจอเว็บสามารถเปิดเมนูการจัดการสต็อกสินค้าและออเดอร์สำหรับตำแหน่งนี้ได้

นายกฤษฎา ต้องไกรเลิศ (รหัส 67115444)

หน้า 3

4. ล็อกอินแอดมิน (Login - Admin)

POST `{{baseUrl}}/auth/login` Status: **200 OK**

REQUEST BODY (JSON)

```
{
  "email": "admin@autopartspro.th",
  "password": "admin123456"
}
```

RESPONSE BODY

```
{
  "success": true,
  "data": {
    "_id": "1",
    "name": "Admin",
    "email": "admin@autopartspro.th",
    "role": "admin",
    "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6ImMSwiaWF0Ij0i"
  }
}
```

คำอธิบายการทดสอบ

ทดสอบส่งคำขอเข้าใช้งานระบบจากผู้ดูแลระบบหลักสูงสุด (role: "admin") เพื่อตรวจสอบสิทธิ์การอนุมัติการจ่ายเงินขั้นสุดท้ายและดูและระบบทั้งหมดของเซิร์ฟเวอร์และฐานข้อมูล

วิเคราะห์ผลลัพธ์

เซิร์ฟเวอร์อนุมัติการเชื่อมต่อ ส่งคำตอบกลับสถานะ 200 OK และส่งโทเคน JWT ที่ระบุบทบาทอย่างเด่นชัดเป็น "admin" พร้อมสิทธิ์ในการลบฐานข้อมูลสินค้าหรืออัปเดตบทบาทผู้ใช้งานในระบบ

นายกฤษฎา ต้องไกรเลิศ (รหัส 67115444)

หน้า 4

5. ดึงข้อมูลอะไหล่ทั้งหมด (Get Products)

GET `{{baseUrl}}/products` Status: **200 OK**

RESPONSE BODY (JSON)

```
{
  "success": true,
  "data": [
    {
      "id": 1,
      "name": "ล้อแม็ก Flowforming 18 นิ้ว Multi-Spoke",
      "brand": "RAYS",
      "carBrand": "BMW",
      "price": 28000
    }
  ]
}
```

คำอธิบายการทดสอบ

ใช้ HTTP Method GET ในการส่งคำขอไปยัง URL แคลตดาล็อกสินค้าอะไหล่แต่งรถทั้งหมดที่มีอยู่ในระบบ เพื่อนำข้อมูลดังกล่าวมาใช้ประมวลผลและทำรายการแสดงผลบนหน้าร้านค้าออนไลน์

วิเคราะห์ผลลัพธ์

ระบบดึงข้อมูลจาก PostgreSQL สำเร็จและตอบกลับมาเป็นอาเรย์ของออบเจกต์สินค้าอะไหล่ (สถานะ 200 OK) โดยส่งคืนคุณสมบัติสำคัญ เช่น ชื่ออะไหล่ แบรินดร์รถยนต์ ราคา จำนวนสต็อกคงเหลือ รวมถึงคะแนนรีวิว เพื่อแสดงผลบนหน้าแรก

นายกฤษฎา ต้องไกรเลิศ (รหัส 67115444)

หน้า 5

6. ค้นหาและกรองอะไหล่ (Search & Filter Products)

GET `{{baseUrl}}/products?category=promotion&search=Flowforming` Status: **200 OK**

RESPONSE BODY (JSON)

```
{
  "success": true,
  "data": [
    {
      "id": 1,
      "name": "ล้อแม็ก Flowforming 18 นิ้ว Multi-Spoke",
      "brand": "RAYS",
      "category": "promotion",
      "price": 28000
    }
  ]
}
```

คำอธิบายการทดสอบ

ใช้ Method GET ร่วมกับ Query Parameters เพื่อจำกัดขอบเขตการค้นหา โดยกำหนดเงื่อนไขหมวดหมู่สำหรับสินค้าลดราคา `category=promotion` และส่งคำค้นหาชื่ออะไหล่รถยนต์เป็นคำว่า `search=Flowforming`

วิเคราะห์ผลลัพธ์

ระบบกรองข้อมูลหลังบ้านและตอบกลับสถานะ 200 OK โดยส่งคืนเฉพาะสินค้าประเภทล้อแม็กที่มีคำว่า Flowforming ในฐานข้อมูลเท่านั้น บ่งชี้ว่าตรรกะการฟิลเตอร์และค้นหาข้อมูลบน Query API ทำงานได้อย่างถูกต้อง

นายกฤษฎา ต้องไกรเลิศ (รหัส 67115444)

หน้า 6

7. เพิ่มอะไหล่ใหม่ (Add Product - Admin Only)

POST `{{baseUrl}}/products` Status: **201 Created**

REQUEST BODY (JSON)

```
{
  "name": "โช้คอัพสปอร์ต OHLINS DFV",
  "description": "โช้คอัพแต่งระดับพรีเมียม ปรับระดับความหนืดและสูงต่ำได้",
  "brand": "OHLINS",
  "carBrand": "BMW",
  "price": 85000,
  "originalPrice": 95000,
  "image": "assets/images/products/ohlins.png",
  "category": "new"
}
```

RESPONSE BODY

```
{
  "success": true,
  "data": {
    "id": 11,
    "name": "โช้คอัพสปอร์ต OHLINS DFV",
    "brand": "OHLINS",
    "price": 85000,
    "stock": 10,
    "isActive": true
  }
}
```

คำอธิบายการทดสอบ

เป็นการส่งข้อมูลของสินค้าตัวใหม่ประเภทอะไหล่และโช้คอัพรถยนต์ระดับพรีเมียม เพื่อขอเพิ่มเข้าไปในคลังสินค้า โดยการทดสอบนี้ระบบจะตรวจสอบความถูกต้องของสิทธิ์ด้วย Authorization Header (JWT Bearer Token) ของแอดมินหรือผู้จัดการระบบที่มีสิทธิ์เท่านั้น

วิเคราะห์ผลลัพธ์

เมื่อมี JWT Token ที่ถูกต้องของบทบาท Admin ระบบทำการอนุมัติบันทึกสินค้าใหม่ลงตาราง `parts` ใน PostgreSQL และตอบกลับสถานะ 201 Created ทันที หากโทเคนหมดอายุหรือไม่มีสิทธิ์ ระบบจะตอบกลับ 403 Forbidden เพื่อรักษาความปลอดภัย

นายกฤษฎา ต้องไกรเลิศ (รหัส 67115444)

หน้า 7

8. ดึงข้อมูลออเดอร์ทั้งหมด (Get Orders)

GET `{{baseUrl}}/orders` Status: **200 OK**

RESPONSE BODY (JSON)

```
{
  "success": true,
  "data": [
    {
      "id": "1",
      "user_id": "11",
      "items": [
        {
          "product": "1"
        }
      ]
    }
  ]
}
```

คำอธิบายการทดสอบ

ใช้ Method GET ร้องขอประวัติการสั่งซื้อทั้งหมดของผู้ใช้งานที่ล็อกอินอยู่ผ่านทาง API Endpoint เพื่อนำข้อมูลออเดอร์เก่าและสถานะมาแสดงบนประวัติออเดอร์ของลูกค้า โดยต้องระบุ Token ใน Header ทุกครั้ง

วิเคราะห์ผลลัพธ์

เซิร์ฟเวอร์ดึงข้อมูลจากตาราง `orders` ในฐานข้อมูล โดยคัดกรองออเดอร์ที่สัมพันธ์กับไอดีของผู้ส่งคำขอ และตอบกลับสถานะ 200 OK พร้อมข้อมูลสินค้าและสถานะชำระเงินของแต่ละคำสั่งซื้ออย่างถูกต้อง

นายกฤษฎา ต้องไกรเลิศ (รหัส 67115444)

หน้า 8

9. สร้างออเดอร์จองอะไหล่ (Create Order - Pay Later)

POST `{{baseUrl}}/orders` Status: **201 Created**

REQUEST BODY (JSON)

```
{
  "paymentMethod": "โอนเงินภายหลัง (แบบสลิป)",
  "shippingAddress": {
    "name": "กฤษฎา ต้องไกรเลิศ",
    "phone": "0812345678",
    "fullAddress": "123 SPU Road, Bangkok"
  },
  "items": [
    {
```

RESPONSE BODY

```
{
  "success": true,
  "data": {
    "id": "5",
    "user_id": "11",
    "subtotal": 28000,
    "shipping_cost": 0,
    "total_amount": 28000,
    "status": "pending"
  }
}
```

คำอธิบายการทดสอบ

ทดสอบส่งรายการซื้อเพื่อสร้างออเดอร์แบบโอนเงินภายหลัง โดยระบุประเภทชำระเงิน สินค้าที่ต้องการซื้อ และจำนวน เพื่อให้ระบบหักลดสต็อกของสินค้าในตาราง `parts` ชั่วคราวก่อนที่จะมีการชำระเงินจริง

วิเคราะห์ผลลัพธ์

ระบบตรวจสอบข้อมูลสินค้าและปริมาณในสต็อกผ่าน ดอนกลับมามีสถานะ 201 Created โดยระบุสถานะเริ่มแรกของคำสั่งซื้อคือ "pending" (รอการชำระเงิน) เพื่อรอให้ลูกค้าอัปโหลดสลิปเป็นหลักฐาน

นายกฤษฎา ต้องไกรเลิศ (รหัส 67115444)

หน้า 9

10. แนบสลิปโอนเงิน (Submit Payment Slip)

POST `{{baseUrl}}/orders/ใส่รหัสออเดอร์ที่นี่/submit-slip` Status: **404 Not Found**

REQUEST BODY (JSON)

```
{
  "slip": "..."
}
```

RESPONSE BODY

```
{
  "success": false,
  "message": "ไม่พบออเดอร์ที่ระบุ"
}
```

คำอธิบายการทดสอบ

ทดลองยิง API เพื่อนำส่งสลิปหลักฐานการชำระเงินโอนด้วยรหัสภาพแบบ Base64 เข้าสู่ระบบสำหรับออเดอร์ที่สั่งซื้อไว้ โดยในส่วนของ URL จะระบุข้อความจำลอง ("ใส่รหัสออเดอร์ที่นี่") แทนที่จะระบุเลขรหัสจริง เพื่อความปลอดภัยในขั้นตอนพัฒนา

วิเคราะห์ผลลัพธ์

ระบบตรวจสอบไม่พบข้อมูลออเดอร์ดังกล่าวในฐานข้อมูลเนื่องจากระบุรหัสจำลอง จึงตอบกลับสถานะ 404 Not Found ซึ่งบ่งชี้ว่าระบบกรองดักจับข้อผิดพลาด (Error Handling) ของเซิร์ฟเวอร์ทำงานได้อย่างถูกต้อง และเสถียร ไม่พบช่องโหว่ความปลอดภัย

11. ผู้จัดการตรวจสอบอนุมัติสลิป (Manager Approve Slip)

POST `{{baseUrl}}/manager/approve-slip/ใส่รหัสออเดอร์ที่นี่` **Status: 404 Not Found**

RESPONSE BODY (JSON)

```
{
  "success": false,
  "message": "ไม่พบข้อมูลออเดอร์เพื่อตรวจสอบหลักฐาน"
}
```

คำอธิบายการทดสอบ

เป็นการใช้บทบาทของผู้จัดการ (Manager) เพื่อกดอนุมัติสลิปการชำระเงินที่ส่งมาจากลูกค้า โดยจะทำการตรวจสอบว่ารูปสลิปมีความถูกต้องหรือไม่ ก่อนปรับสถานะออเดอร์ในขั้นตอนแรกจากรหัสออเดอร์บน URL

วิเคราะห์ผลลัพธ์

เมื่อใส่รหัสออเดอร์จำลองใน URL ระบบส่งผลตอบกลับสถานะ 404 Not Found ทันที แต่ถ้าหากเปลี่ยนไประบุด้วยรหัสสั่งซื้อที่ถูกต้องจริง (เช่น ID: 5) ระบบจะปรับเปลี่ยนสถานะของคำสั่งซื้อเป็น "manager_approved" เพื่อส่งข้อมูลให้ผู้ดูแลทำการยืนยันบัญชีปลายทางถัดไป

12. แอดมินยืนยันยอดเงินสุดท้าย (Admin Final Confirm)

POST `{{baseUrl}}/admin/confirm-order/ใส่รหัสออเดอร์ที่นี่` **Status: 404 Not Found**

RESPONSE BODY (JSON)

```
{
  "success": false,
  "message": "ไม่พบออเดอร์เป้าหมายเพื่อทำเรื่องยืนยัน"
}
```

คำอธิบายการทดสอบ

ทดสอบส่งเรื่องให้ระบบหลังบ้านที่มีแอดมิน (Admin) คอยตรวจสอบยอดเงินฝากเข้าจริงผ่านระบบธนาคาร เมื่อเงินเข้าเรียบร้อย แอดมินจะกดยืนยันออเดอร์จากระบบหลังบ้านเพื่อเปลี่ยนสถานะออเดอร์ให้พร้อมจัดส่งสินค้า

วิเคราะห์ผลลัพธ์

ระบบการตรวจสอบสิทธิ์ความปลอดภัยส่งค่าตอบกลับ 404 Not Found เนื่องจากความไม่ถูกต้องของรหัสออเดอร์จำลองใน URL โดยในกระบวนการทำงานปกติเมื่อข้อมูลถูกต้อง สถานะจะอัปเดตเป็น "confirmed" เพื่อดำเนินการสั่งบรรจุและจัดเตรียมส่งมอบชิ้นงาน

13. ผู้จัดการจัดส่งสินค้า (Manager Ship Order)

POST

{{baseUrl}}/manager/ship-order/ใส่รหัสออเดอร์ที่นี่

Status: 404 Not Found

RESPONSE BODY (JSON)

```
{
  "success": false,
  "message": "ไม่พบรหัสการจัดส่งเป้าหมาย"
}
```

คำอธิบายการทดสอบ

เป็นการส่งเรื่องอัปเดตระบบในขั้นตอนการจัดส่งสินค้า (Ship Order) โดยเจ้าหน้าที่ฝ่ายจัดการ หลังนำสินค้าอะไหล่แต่งรถส่งมอบให้บริษัทโลจิสติกส์แล้ว จะทำการอัปเดตสถานะออเดอร์และบันทึกรหัสตรวจสอบพัสดุ (Tracking Number) ลงในระบบเพื่อปิดรอบการขาย

วิเคราะห์ผลลัพธ์

เซิร์ฟเวอร์ตอบกลับสถานะ 404 Not Found เนื่องจากความไม่เข้าคู่ของรหัสออเดอร์ในขั้นตอนพัฒนา ในระบบปฏิบัติงานจริงระบบจะเปลี่ยนสถานะเป็น "shipped" พร้อมแจ้งเลขพัสดุผ่านทางระบบหน้าบ้านให้ลูกค้าสามารถเข้าไปติดตามการขนส่งได้

